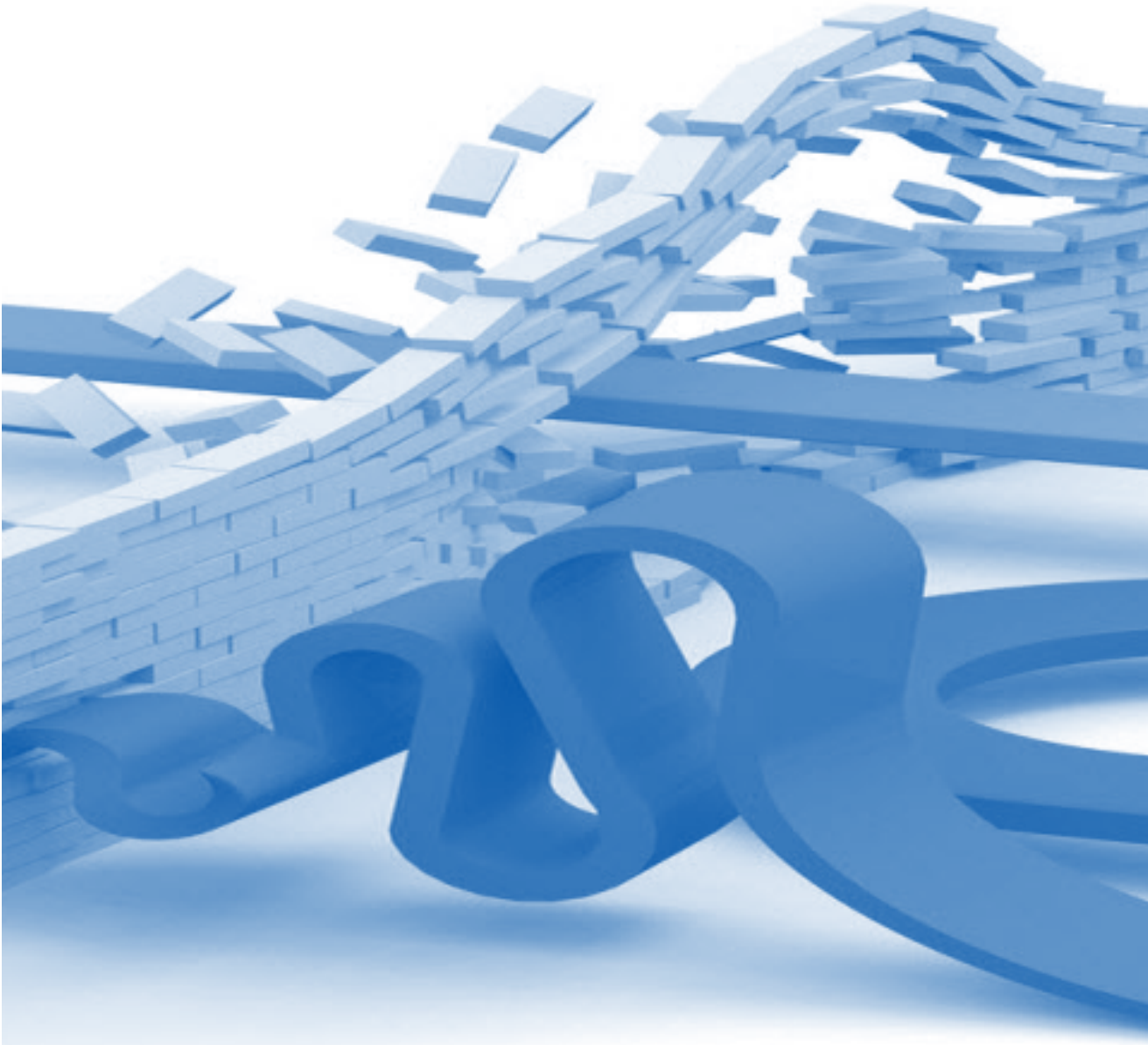




SECURITY TESTING

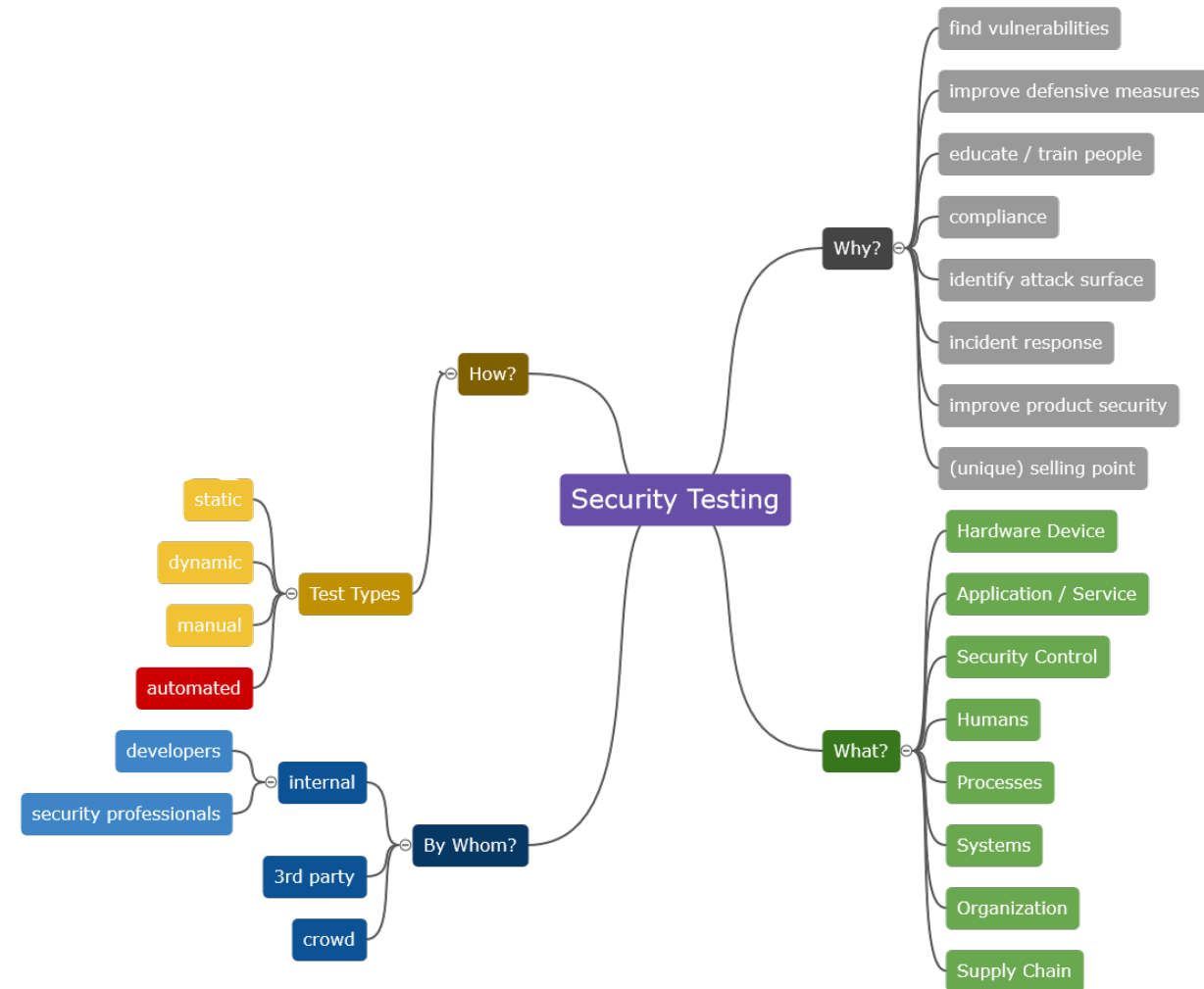
Prof. Dr. Bernhard Tellenbach

- Security Testing Methods
 - Vulnerability Scanning
 - Classical Penetration Testing
 - Red Teaming / Ethical Hacking
 - Purple Teaming
 - Breach & Attack Simulation
 - Bug Bounty Programs
- Penetration Testing
 - Penetration testing methodologies
 - Penetration testing phases
 - The pre-engagement phase

Goals

- You can name **six different security testing methods** can discuss what method is best when given the motivation for a security test
- You know what a **penetration test** is and you can explain what it can be used for
- You can name at least two **standards** that provide guidance on how to do a penetration test
- You can explain the role and **important parameters** (scope, rules of engagement, test method) of the **pre-engagement** phase

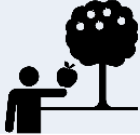
The Big Picture



Vulnerability Scanning

Purpose	Identify well-known vulnerabilities Compliance (e.g., GDPR, HIPAA, PCI DSS,...)
Attacker Goal	-
Assets in Scope	Source code, applications, systems, entire infrastructures
Result	Potential vulnerabilities and a generic risk rating
Method	Fully automated (software / appliance / SaaS) • e.g., OpenVAS (infrastructure), LGTM.com (source code)
Requirement	Mature vulnerability management process • resources/skills to verify, prioritize and fix them
Frequency	Continuous • Vulnerability signatures and assets are not static

Classical Penetration Testing

Purpose	Find as many vulnerabilities as possible and get fixing-advice Compliance ¹ (e.g., GDPR, HIPAA, PCI DSS,...)
Attacker Goal	Efficiently find many vulnerabilities • Mainly «easy to find» vulnerabilities 
Assets in scope	One / a few • e.g., a single application, system or service
Result	Verified vulnerabilities and their risk rating plus advice how to fix them
Method	(Semi-)automated tools/scanners and standardized testing procedures (for web-apps, e.g., OWASP testing guide)
Requirement	Mature vulnerability management processes, test environment ²
Frequency	1 – 4 times a year Once per new version/release

Red-Team Testing

Purpose	Test the organization's detection and response capabilities
Attacker Goal	Find a way to achieve a stated goal and don't get caught trying e.g., steal customer data, become domain admin, install spyware on a designated asset, ...
Assets in scope	Many / All [physical, human, cyber]
Result	Goal achieved (yes/no) and how it was achieved
Method	Goal and scope dependent, social engineering is often part of it
Requirement	Mature security program – i.e., vulnerability management, security testing & monitoring, and incident handling in place
Frequency	Periodically (?)

Purple-Team Testing

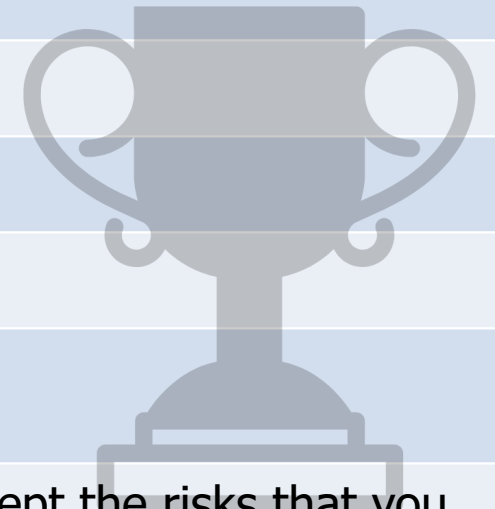
Purpose	Improve security posture • focus on detective/preventive controls • identify malicious actors in environment	 The diagram illustrates the Purple Team Testing process. It features three horizontal tracks: a red track for the Red team (Attack simulation), a purple track for the Purple team (Resilience testing, Improve organization security posture (common goal)), and a blue track for the Blue team (Implementing controls, Incident response). Arrows show the flow of the process, with the Purple team's goal being the common objective for all teams.
Attacker Goal	Help the blue ¹ team to catch them / learn from them	
Assets in scope	Predetermined systems/employees	
Result	Improvements to security controls (e.g., new detection rules) and plan to resolve issues that could not be addressed during the exercise	
Method	Simulate (relevant) attack patterns and scenarios	
Requirement	Interfaces and collaboration between incident response, security tooling, network engineers and vulnerability management work well	
Frequency	Periodically (e.g., once per quarter)	

Breach & Attack Simulation

Purpose	Improve security posture: • Focus on detective/preventive controls • Use a set of «prominent» attack vectors (e.g., MITRE ATT&CK) • Usually, multi-step attacks along the cyber kill chain
Attacker Goal	-
Assets in scope	Any* (determined by the selected attack types/scripts)
Result	Report on resilience against the scripted cyber attacks
Method	Automated testing platform (e.g., SaaS) implementing scripted multi-stage attacks (e.g., implementing the steps in the cyber-kill chain)
Requirement	Same as for purple-team testing, big-budget blue-team
Frequency	Continuous

Bug Bounty Program

Purpose	Find vulnerabilities and pay only if vulnerabilities are found • Public – anyone can participate • Private – selection process / by invitation only
Attacker Goal	Earn money (sometimes also «prestige»)
Assets in scope	Often a single application/service/system
Result	Vulnerability reports
Method	According to the program • Specifies what is allowed (or not allowed)
Requirement	Appropriate legal framework, willingness to «go public», accept the risks that you do not know/trust the testers,...
Frequency	Continuous



Overview – When to apply which Method

	Vulnerability Scanning	Penetration Testing	Red Teaming	Purple Teaming	Bug Bounty	Breach & Attack Simulation
Finding known vulnerabilities (in 3 rd -party libs/apps/systems before or during operation)	x	x			(x)	
Finding vulnerabilities ([self-developed] apps/systems before or during operation)	(x) ¹	x			x	
Improve product security	(x) ¹	(x) ²			x	
Improve defensive measures				x		x
Test defenses, incident response			x	(x)		x
Educate/train blue team			(x)	x		(x)
Compliance	x	(x)				

¹ Specialized scanners. Can detect vulnerabilities that can be found with “simple” testing patterns (e.g., web-application scanners looking for SQL-injection or XSS vulnerabilities) under the condition that the vulnerable item/action in the application/system can be found/triggered (e.g., web-form supplying the data) by the scanner.

² Pen-testing can help here, but activities earlier in the product development cycle are far more effective and should be prioritized (e.g., threat modelling, security architecture review, code review and static code analysis)

Note: For security testing methods it might be relevant whether the system under test is **internal**, **public** or **hosted on third party infrastructure** (in the cloud). For example, public bug bounty programs are usually not an option for internal systems.

Penetration Test – Definition

- Several definitions exist:

- Penetration testing is **security testing** in which assessors **mimic real-world attacks** to identify methods for **circumventing the security features** of an application, system, or network.
[NIST SP 800-115]

- A penetration test is the **simulation of an attack** on a system, network, piece of equipment or other facility, with the objective of **proving how vulnerable** it can be to a real attack.

[K. M. Henry, "Penetration Testing - Protecting Networks and Systems"]

What does this prove?

- 1x pen-tester, 10 days, 5000\$ gear
- Result: No vulnerability found

- A more business-oriented definition:

- A penetration test serves to **analyse** the entire or **designated parts** of the IT-environment of a company with the **goal to find and exploit vulnerabilities** and to identify the **business risk** associated with them

Scope?

Pentest is a snapshot!

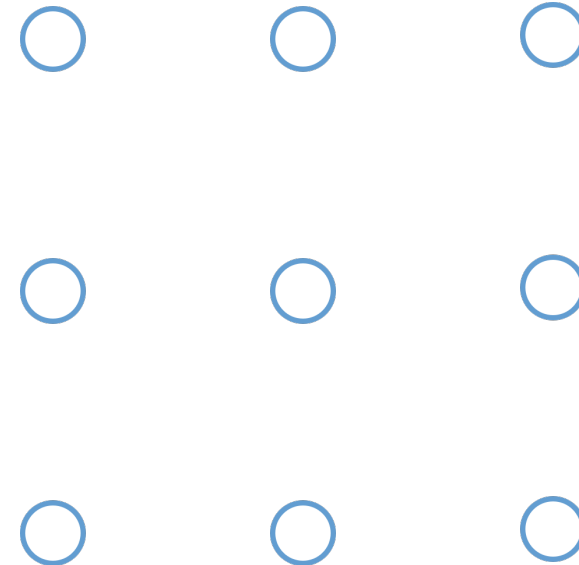
«Rating»

Penetration Testing - Motivation

- Find **holes** in your defences **before attackers** do!
- Find **holes** difficult/impossible to find with automated tools
- Test defenders to successfully **detect and respond** to attacks
- Prove that security issues exist to **management**
- Raise overall security **awareness**
- Verify secure system **configurations** and/or test **new technology**
- Discover gaps in **compliance** posture and satisfy **legal** and/or governmental requirements (e.g., PCI-DSS, HIPAA,..)
- ...

Focus and Scope

- Common types of penetration tests focus on:
 - Hacking and controlling **IT assets**
 - e.g., a network or a web application
 - Getting **access** to a certain piece of **information**
 - e.g., customer data, credit card numbers
 - Penetrating **physical security**
 - e.g., enter a building and access a specific asset
 - **Social engineering**
 - e.g., convincing someone to open an attachment
- It has a **clear** but **limited scope**
 - Web application penetration test conducted only from the point of view of the Internet browser
 - Access a system managing bank accounts of non-Swiss citizens from an outsider's point of view.
- Success factors:
 - Experience, skills, equipment, lateral and **out of the box thinking**



Connect the dots!
4 Straight lines only!

Out of the Box Thinking / Thinking Outside the Box

- Think about 10 ways to turn off the light in this room

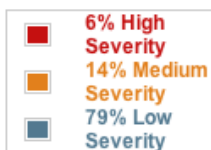
Is this a Penetration Test?



Executive Summary: My Network Scan

[>PRINT](#)

TOP 10 HOSTS with ISSUES



192.168.1.13	High Severity problem(s) found
192.168.1.79	High Severity problem(s) found
192.168.1.65	High Severity problem(s) found
192.168.1.30	High Severity problem(s) found
192.168.1.16	High Severity problem(s) found
192.168.1.10	Medium Severity problem(s) found
192.168.1.60	Medium Severity problem(s) found
192.168.1.11	Medium Severity problem(s) found
192.168.1.81	Medium Severity problem(s) found
192.168.1.80	Medium Severity problem(s) found

PLUGIN IDS	ISSUES
22964	45
19506	22
10180	22
10287	20
35716	19
10107	16
11936	15
24260	14
10114	14
25220	13
45590	12
25221	11
10881	10
10267	10
21643	8
10863	8
39520	7
11111	7
12218	6
12053	6

PLUGIN IDS	SEVERITY	# OF ISSUES	SYNOPSIS
47606	High	2	D-Link DCC Protocol Security Bypass The remote network service is affected by a security bypass vulnerability.
50504	High	1	Web Common Credentials It is possible to access protected web pages with common credentials.
50309	High	1	[DSA2122] DSA-2122-1 glibc The remote host is missing the DSA-2122 security update
49766	High	1	[DSA2116] DSA-2116-1 freetype The remote host is missing the DSA-2116 security update
42411	High	1	Microsoft Windows SMB Shares Unprivileged Access It is possible to access a network share.

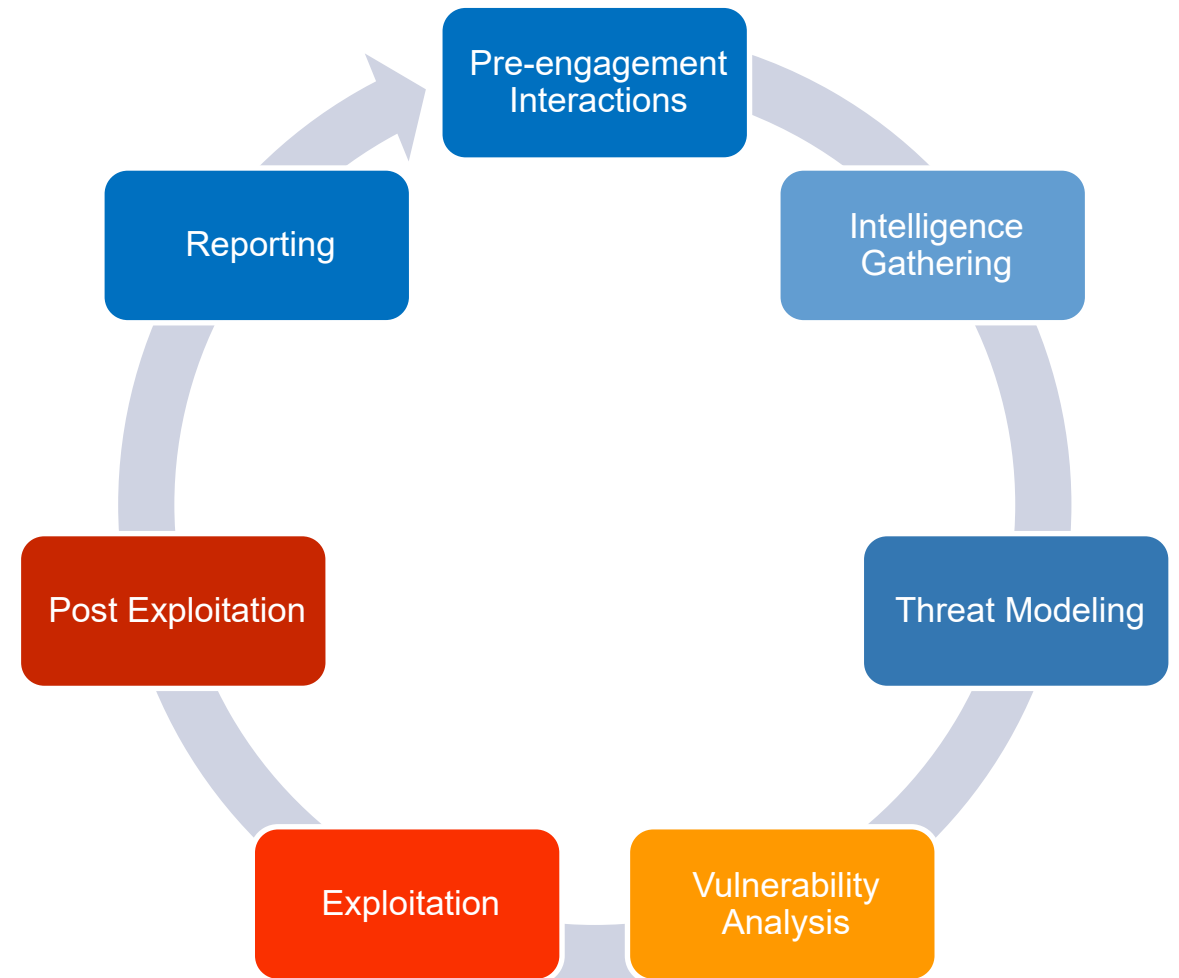
How to Pentest? Penetration Testing Methodologies

- OSSTMM - Open Source Security Testing Methodology Manual
 - Methodology for testing security systems **for everything**
 - From guards and locked doors to mobile communication and satellites
 - Includes a **mathematical model** to determine the **security level** and make systems/tests **comparable**
- OWASP Testing Guide (V 4.0)
 - Security testing of **web applications**
 - Includes **hands-on advice** and references for **tools**
- The NIST SP 800-115 Technical Guide to Information Security Testing & Assessment
 - Covers process typically applied in pentesting (planning, detailed analysis, dealing with validation of discovered concerns)
 - Appendix lists some Linux-tools for typical pentesting tasks
- Penetration Testing **Execution** Standard (PTES)
 - Explains the **basic principles and steps** required to conduct a penetration test
 - Effort of people from the industry
 - Incomplete/unfinished and with respect to technical guidance outdated
- A lot of other resources (checklists, guides, training material,...) are available on the Internet
 - E.g., from the SANS Institute, offering a series of courses in this domain

=> At least read this, if pentesting is your main business

=> You should study this when you need to pentest web applications

Penetration Test: Phases



GOAL

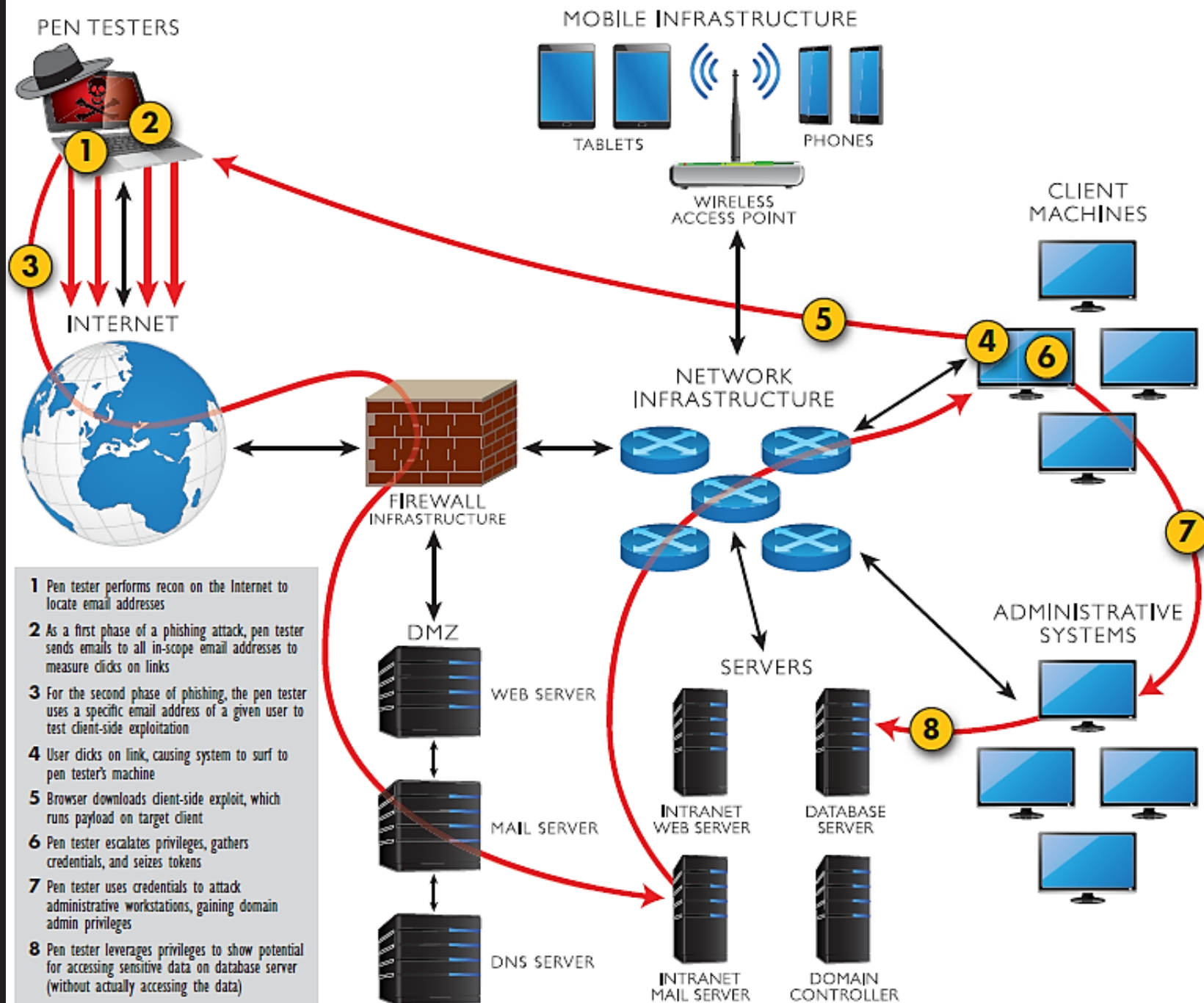
Determined whether sensitive data on intranet could be compromised

TOOLS AND TECHNIQUES APPLIED

- Recon-ng (Step 1)
- Social Engineering Toolkit (Steps 2 and 3)
- Metasploit (Step 5)
- Meterpreter (Step 6)
- Mimikatz (Step 6)
- Lateral movement and pass-the-hash (Steps 6, 7, and 8)
- Detailed post-exploitation analysis (Step 8)

RELATED SANS COURSES

- SEC504
- SEC506
- SEC561
- SEC562
- SEC580



Questions:

- What phases can you identify?
- Which ones are missing?

Pre-engagement Interactions



Pre-Engagement Interactions – Overview

- **Scoping** – Define what is to be tested
 - An **in-depth** test of a **single application** attacked?
 - Over the Internet without the «help» of employees?
 - Test a **wide range** of IP addresses to **find a way into** the company network?
- **Rules of Engagement** – How that the testing is to occur
 - Method, Timeline, locations, evidence Handling,...
- **Costs** – What are the costs for the test?
 - Estimation, fixed price vs. on time and material basis, ...

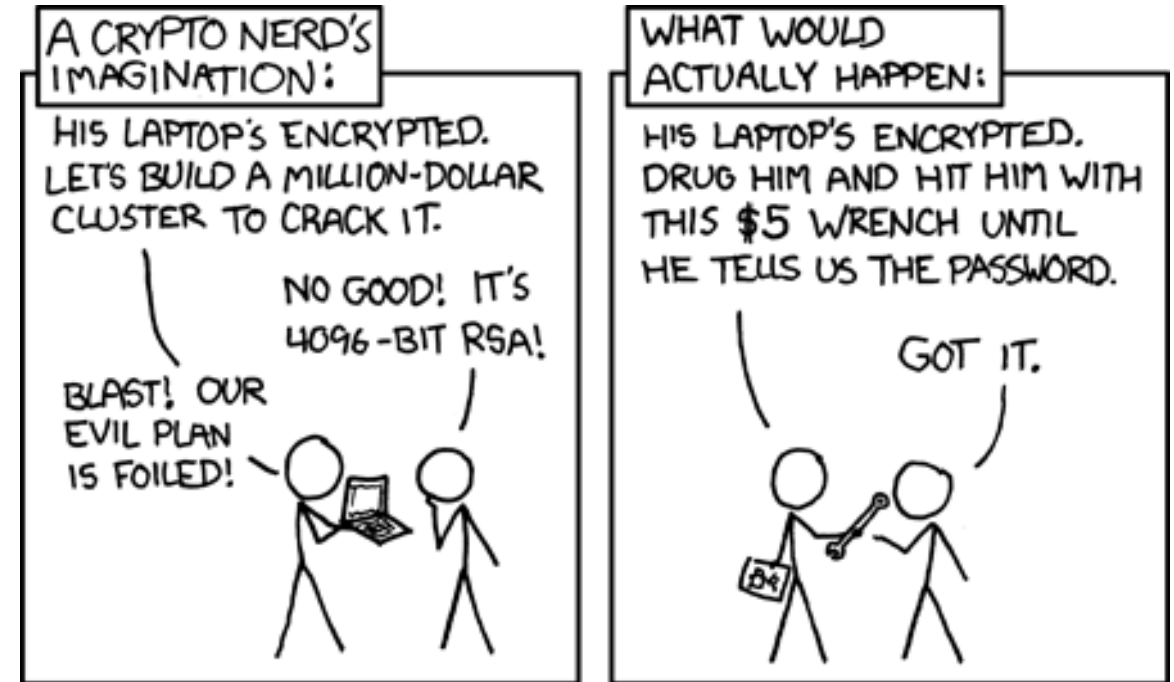
Scope – What Does the Client Want?

- Clients are often **unaware** of exactly what it is **they need tested** or can't communicate effectively what they're expecting
 - «We need to test whether someone can break into our network»
- **What** the client is looking to **gain** from the test
 - Information on vulnerabilities and the associated risk
 - Recommendations on how to fix the problems found
 - A checkmark in a checkbox ()
 - Discredit someone in a different department ()
- **Why** the client wants/must do a pentest
 - Suspects that they have a serious security problem
 - To meet compliance requirements ()
 - Management wants the new service tested before going live
 - ...
- Customer:
«Please lower the rating from HIGH to MEDIUM. If you don't, we cannot go live with the product and must do a full dev and review cycle. The release has already been communicated to customers!»
- What do you do? Discuss!



Scope – What does the Client Want?

- Common penetration test types
 - Network (e.g., get access to the intranet)
 - Web application (e.g., get access to data)
 - Wireless network (e.g., get network access)
 - Physical (e.g., enter a secured area and access a specific asset)
 - Social engineering (e.g., obtain credentials)
- What the means (channels) used to interact with the assets should be
 - Human
 - Physical
 - Wireless
 - Telecommunications
 - Data Networks



Source: <https://xkcd.com/538/>

Scope – What is to be Tested?

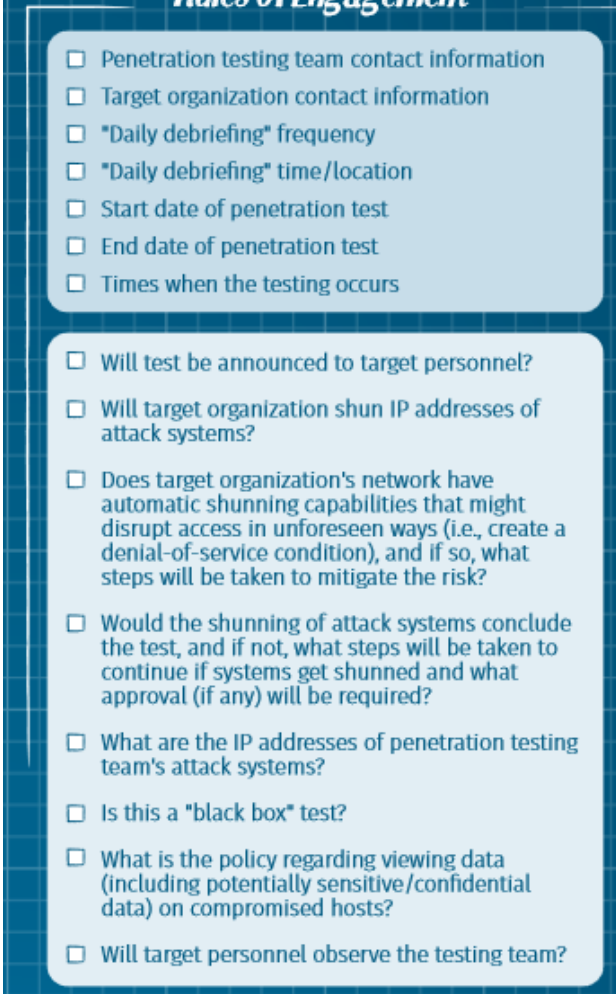
- What assets are **included/excluded**?
 - e.g., the entire web application except for the billing component
 - e.g., list of IP addresses/networks
- Are assets from **third parties** affected?
 - Cloud services, Internet service provider, Web hosting provider, Managed security service provider, ...
 - Check **terms of service**
 - Check **impact on test results**
 - e.g., filtering of malicious traffic, DoS etc.
- Use **questionnaires/checklists** to guide the process of defining the scope
 - To avoid pitfalls, you need experience

Scoping

- ☐ What are the target organization's biggest security concerns? (Examples include disclosure of sensitive information, interruption of production processing, embarrassment due to website defacement, etc.)
- ☐ What specific hosts, network address ranges, or applications should be tested?
- ☐ What specific hosts, network address ranges, or applications should explicitly NOT be tested?
- ☐ List any third parties that own systems or networks that are in scope as well as which systems they own (written permission must have been obtained in advance by the target organization).
- ☐ Will the test be performed against a live production environment or a test environment?
- ☐ Which of the following testing techniques will the penetration test include:
 - ☐ Ping sweep of network ranges?
 - ☐ Port scan of target hosts?
 - ☐ Vulnerability scan of targets?
 - ☐ Penetration into targets?
 - ☐ Application-level manipulation?
 - ☐ Client-side reverse engineering?
 - ☐ Physical penetration attempts?
 - ☐ Social engineering of people?
 - ☐ Other?
- ☐ Will penetration test include internal network testing?
 - ☐ If so, how will access be obtained?
- ☐ Are client/end-user systems included in scope?
 - ☐ If so, how many client systems will be targeted?
- ☐ Is social engineering allowed?
 - ☐ If so, how may it be used?
- ☐ Are denial-of-service attacks allowed?
 - ☐ Are dangerous checks/exploits allowed?

Pre-engagement Interactions – Rules of Engagement

- How the testing is to occur, including the **test method**
- **Timeline** – What happens when between start and end date?
- **Status meetings** - Definition of regular status meetings
 - Agenda: Plan, progress, problems
- **Time of Day to Test** – Limitations on when the testing should occur
 - E.g., only between 20:00 and 06:00 (outside of business hours) and the backup system should not be attacked between 00:00 and 04:00
- **Use of evasion/stealth** techniques
 - Depends on test methodology (black-box, white-box, ...)
- **Evidence handling** - How to handle/store results
 - Encrypted and limit access on a need-to-know basis
- **Permission to test document** - States **scope** and **acknowledges awareness** of the tester's activities



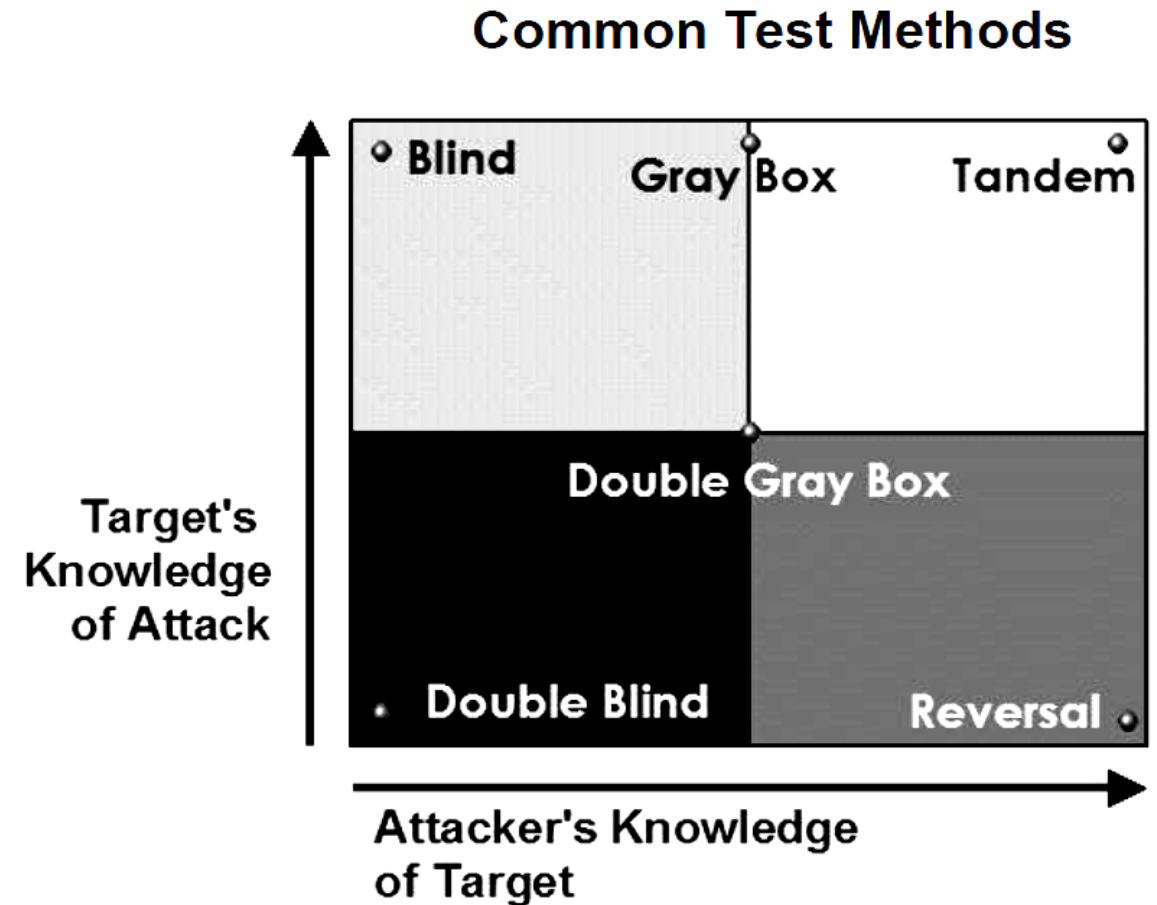
Rules of Engagement

- ☐ Penetration testing team contact information
- ☐ Target organization contact information
- ☐ "Daily debriefing" frequency
- ☐ "Daily debriefing" time/location
- ☐ Start date of penetration test
- ☐ End date of penetration test
- ☐ Times when the testing occurs

- ☐ Will test be announced to target personnel?
- ☐ Will target organization shun IP addresses of attack systems?
- ☐ Does target organization's network have automatic shunning capabilities that might disrupt access in unforeseen ways (i.e., create a denial-of-service condition), and if so, what steps will be taken to mitigate the risk?
- ☐ Would the shunning of attack systems conclude the test, and if not, what steps will be taken to continue if systems get shunned and what approval (if any) will be required?
- ☐ What are the IP addresses of penetration testing team's attack systems?
- ☐ Is this a "black box" test?
- ☐ What is the policy regarding viewing data (including potentially sensitive/confidential data) on compromised hosts?
- ☐ Will target personnel observe the testing team?

Common Test Methods (OSSTMM)

- Blind
 - Ethical Hacking
 - War Gaming, Role Play
- Double Blind
 - Black Box testing
 - «Classical» Penetration Test
- Gray Box
 - Vulnerability Test
- Double Gray Box
 - White Box testing
- Tandem
 - Crystal Box testing
- Reversal
 - Red Team Exercise



Evidence Handling – Sensitive Information

- Do not store/access personally identifiable information (PII)
- Do not store/access sensitive personally identifiable information (PII)
 - Religion, race, political opinions and activities,...
- No personal health information (PHI)

But how to prove that access to this information could be obtained?



Rules of Engagement – Permission to Test Document

- States scope and **acknowledges awareness** of the tester's activities
- Includes **ALL permissions** required + granted (customer, 3rd parties, ...)
 - For example, testing a service deployed in the Microsoft cloud is permitted (some limits apply)
- «Online» tests: **Liability** in case of system instabilities/crashes
 - Testing can lead to system instability / crash despite all due care => tester shall **not be hold liable** for this



PERMISSION TO TEST DOCUMENT: RULES OF ENGAGEMENT TO PERFORM PENETRATION TESTING ON THE MICROSOFT CLOUD

The purpose of this program is to enable customers to test their services hosted in Microsoft Cloud services without causing harm to any other Microsoft Cloud customers. The following activities are prohibited:

Testing or testing assets belonging to any other Microsoft Cloud customers.

Obtaining access to any data that is not wholly your own.

Performing any kind of denial of service testing.

Performing network intensive fuzzing against any asset except your Azure Virtual Machine.

Performing automated testing of services that generates significant amounts of traffic.

Unauthorizedly accessing any other customer's data.

Going beyond "proof of concept" repro steps for infrastructure execution issues (i.e. proving that you have sysadmin access with SQLi is acceptable, but a shell is not).

Using our services in a way that violates the Acceptable Use Policy, as set forth in the [Microsoft Online Service Terms](#).

Attempting phishing or other social engineering attacks against our employees.

The following activities are encouraged:

Using a small number of test accounts and/or trial tenants for demonstrating and proving cross-account or cross-tenant data access. However, it is prohibited to use one of these accounts to access the data of another customer or account.

Performing a port scan, or run vulnerability assessment tools against your own Azure Virtual Machines.

Testing your application by generating traffic which is expected to be seen during the normal course of business. This includes testing surge capacity, performance, and security monitoring and detections (e.g. generating anomalous security logs, dropping [EICAR](#), etc).

Attempting to break out of a shared service container such as Azure Websites or Azure Functions. However, should you succeed you must both immediately report it to Microsoft and cease digging deeper. Deliberately accessing another customer's data is a violation of the terms.

Obtaining conditional access or [mobile application management \(MAM\)](#) policies within Microsoft Intune to test the enforcement of the restrictions and policies.

Notwithstanding these prohibitions, Microsoft reserves the right to respond to any actions on its networks that appear to be malicious. Many automated mitigation measures are employed across the Microsoft Cloud. These will not be disabled to facilitate a penetration test.



Pre-engagement Interactions - Communication

- Establish lines of communication - How often you interact with the customer and how?
- Emergency contact information
 - List with contacts from all relevant parties (*incl. full name, title and operational responsibility*)
 - Authorization to discuss details of the testing activities
 - Two forms of 24/7 immediate contact if possible (*e.g., instant messenger and cell phone*)
 - How to exchange (large) files (*e.g., secure sharing platform, must be tested and ready*)
- Incident reporting process - Target is aware* of when the tests are being conducted
 - Or do you want the SOC to call upper management in the middle of the night?
- Status report frequency
 - An ignored customer is a former customer
- Communication channels - How to communicate with the customer securely

Challenge - Scope Creep

- Extension/alteration of the scope requiring more time and effort to complete the engagement
- Client: «You did great work by discovering this problem; please verify that this can indeed be exploited»
- Pentester: «Thanks a lot! Sure, we can do this!»

=> What to do in such a case? Discuss!